

**UNIVERSIDAD COMPLUTENSE
DE
MADRID**

MASTER EN CIBERSEGURIDAD



ALUMNO: Darwin Marcani Rojas

PROFESOR: D. Jesús Damián Angosto Iglesias

España-Madrid

2025

Contenido

1. Puntos evaluables	5
Punto 1	5
Punto 2	6
Punto 3	7
Informe Forense Digital	8
1. Control de Versiones	8
2. Resumen Ejecutivo	8
3. Línea de Tiempo	9
4. MITRE ATT&CK TTPs	10
5. Descripción del Incidente	10
5.1 Alcance de la investigación	11
6. Dispositivos Proporcionados	11
7. Trabajos Realizados	11
7.1 Verificación de Integridad	11
7.2 Análisis de Memoria RAM — Volatility 3	12
7.2.1 Identificación del sistema	12
7.2.2 Hallazgo 1 — Contraseña del usuario	12
7.2.3 Hallazgo 2 — Procesos sospechosos	13
7.2.4 Hallazgo 3 — Conexiones de red	13
7.3 Análisis de Imagen de Disco	14
7.3.1 Montaje de la evidencia	14
7.3.2 Extracción de artefactos — KAPE	14
7.3.3 Hallazgo 4 — Análisis del escritorio del usuario	14
7.3.4 Hallazgo 5 — Keylogger (key.exe)	14
7.3.5 Hallazgo 6 — Ejecución de comandos y borrado	15
7.3.6 Hallazgo 7 — Análisis de correo electrónico (Thunderbird)	15
7.3.7 Hallazgo 8 — Dispositivos USB conectados	16
8. IOCs — Indicadores de Compromiso	16
9. Conclusiones	18

9.1 ¿Se accedió a los documentos confidenciales?	18
9.2 ¿Existen indicios de exfiltración y TTPs?	18
9.3 ¿Se conectó algún dispositivo USB?	18
9.4 ¿Hubo conexiones a la nube o correos web?	18
9.5 Conclusión general	19
10. Recomendaciones y Plan de Acción	20
Prioridad Alta — Acción inmediata	20
Prioridad Media — Corto plazo.....	20
Prioridad Baja — Largo plazo	20

Contenido de tablas

Tabla 1.	Ficheros Eliminados	6
-----------------	---------------------------	---

Contenido de figuras

Figura 1.	Volatility/Hashes	5
Figura 2.	CrackStation.....	5
Figura 3.	Archivos .xls	6

1. Puntos evaluables

Punto 1

Averigua la contraseña del usuario. Esto es necesario para, en caso de que sea necesario, recrear la máquina virtual y realizar un examen más exhaustivo.

R.

Usuario: IEUser

Hash NT: fc525c9683e8fe067095ba2ddc971889

Contraseña: PasswOrd!

Tipo hash: NTLM

Herramientas: Volatility 3 (windows.hashdump) + CrackStation

```
C:\Windows\System32>C:\Forens\Herramientas\Volatility\vol.exe -f "C:\Forens\Evidencias\ram.raw" windows.hashdump
Volatility 3 Framework 2.27.0
volatility3\framework\deprecation.py:28: FutureWarning: This API (volatility3.plugins.windows.registry.hashdump.Hashd
ump.run) will be removed in the first release after 2026-09-25. Please ensure all method calls to this pl
ugins.windows.registry.hashdump.Hashdump rather than volatility3.plugins.windows.hashdump.Hashdump.

User      rid      lmhash  nthash
volatility3\framework\deprecation.py:105: FutureWarning: This plugin (volatility3.plugins.windows.hashdump.Hashdump)
has been renamed and will be removed in the first release after 2026-09-25. Please ensure all method calls to this pl
ugin are replaced with calls to volatility3.plugins.windows.registry.hashdump.Hashdump
Administrator  500      aad3b435b51404eeaad3b435b51404ee      fc525c9683e8fe067095ba2ddc971889
Guest          501      aad3b435b51404eeaad3b435b51404ee      31d6cfe0d16ae931b73c59d7e0c089c0
IEUser         1000     aad3b435b51404eeaad3b435b51404ee      fc525c9683e8fe067095ba2ddc971889
sshd           1001     aad3b435b51404eeaad3b435b51404ee      31d6cfe0d16ae931b73c59d7e0c089c0
sshd_server    1002     aad3b435b51404eeaad3b435b51404ee      8d0a16cfc061c3359db455d00ec27035
testuser       1003     aad3b435b51404eeaad3b435b51404ee      259745cb123a52aa2e693aaacca2db52
```

Figura 1. Volatility/Hashes

CrackStation Password Hashing Security Defuse Security

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

fc525c9683e8fe067095ba2ddc971889

No soy un robot

Este sitio supera la cuenta gratuita de reCAPTCHA Enterprise

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
fc525c9683e8fe067095ba2ddc971889	NTLM	PasswOrd!

Figura 2. CrackStation

Punto 2

Se sospecha que el usuario realizó acciones para la eliminación de ficheros y ocultar su rastro, evitando la papelera de reciclaje. Averigüe si ha habido ejecución de comandos y, de ser así, encuentra el nombre del fichero eliminado.

R.

Durante el análisis del sistema se identificó el uso de SDelete64, herramienta de Microsoft diseñada para la eliminación permanente de archivos, y así poder eludir la papelera de reciclaje y sobrescribiendo el espacio en disco para dificultar su recuperación.

El análisis del archivo Prefetch SDELETE64.EXE-1BCED5FB.pf confirma que dicha herramienta fue ejecutada en 2 ocasiones desde el escritorio del usuario IEUser, registrándose la última ejecución el 2021-03-23 a las 22:55:23.

```
C:\Windows\System32\cmd.exe /c (x) C:\ForensicAnalysis\Kape_Output\tsv
1488,11,True,16129,2,.\$Recycle.Bin\S-1-5-21-2213123778-2569645789-4120232176-1000,$R20EGV.xls,.xls,70656,1,,False,True,False,False,False,Archive,
DosWindows,2021-03-19 10:18:12.3908868,,2021-03-19 10:18:14.1790393,,2021-03-23 23:08:59.6422856,2021-03-23 23:08:31.7985356,2021-03-19 10:18:12.3908868,,
1174990392,322696918,1727,539efd51-8c2a-11eb-97f4-000c294e8db9,,C:\ForensicAnalysis\Kape_Output\tsv
1488,11,True,16129,2,.\$Recycle.Bin\S-1-5-21-2213123778-2569645789-4120232176-1000,$R20EGV.xls:Zone.Identifier,.Identifier,26,1,,False,False,True,False,
False,False,Archive,DosWindows,2021-03-19 10:18:12.3908868,,2021-03-19 10:18:14.1790393,,2021-03-23 23:08:59.6422856,2021-03-23 23:08:31.7985356,2021-03-
19 10:18:12.3908868,,1174990392,322696918,1727,539efd51-8c2a-11eb-97f4-000c294e8db9,, "[ZoneTransfer]
16907,7,True,477,2,.\Users\IEUser\AppData\Roaming\Microsoft\Windows\Recent\CLIENTES DEL BANCO.xls.lnk,.lnk,3907,1,,False,False,False,False,False,Ar
chive,Windows,2021-03-23 23:07:55.5032231,,2021-03-23 23:07:55.5032231,,2021-03-23 23:07:55.5032231,,1174866768,3226731826,1
577,,C:\ForensicAnalysis\Kape_Output\tsv
35846,10,True,477,2,.\Users\IEUser\AppData\Roaming\Microsoft\Windows\Recent\Plan de cuentas.xls.lnk,.lnk,3866,1,,False,False,False,False,False,Ar
chive,Windows,2021-03-23 23:08:31.7985356,,2021-03-23 23:08:31.7985356,,2021-03-23 23:08:31.7985356,,1174977312,3226947341,157
7,,C:\ForensicAnalysis\Kape_Output\tsv
37162,11,True,16129,2,.\$Recycle.Bin\S-1-5-21-2213123778-2569645789-4120232176-1000,$IN20EGV.xls,.xls,544,1,,False,False,False,False,False,Archive,
DosWindows,2021-03-23 23:08:59.6422856,,2021-03-23 23:08:59.6422856,,2021-03-23 23:08:59.6422856,,1174989936,3226969217,683,
,,C:\ForensicAnalysis\Kape_Output\tsv
44567,9,True,16129,2,.\$Recycle.Bin\S-1-5-21-2213123778-2569645789-4120232176-1000,$IMQ087V.xls,.xls,544,1,,False,False,False,False,Archive,D
osWindows,2021-03-23 23:08:59.6422856,,2021-03-23 23:08:59.6422856,,2021-03-23 23:08:59.6422856,,1174990656,3226970515,683,
,,C:\ForensicAnalysis\Kape_Output\tsv
85030,8,True,16129,2,.\$Recycle.Bin\S-1-5-21-2213123778-2569645789-4120232176-1000,$RMOQ87V.xls,.xls,12800,1,,False,True,False,False,False,Archive,
DosWindows,2021-03-19 10:19:02.5814838,,2021-03-19 10:19:04.6872490,,2021-03-23 23:08:59.6422856,2021-03-23 23:07:55.5032231,2021-03-19 10:19:02.5814838,
1174991112,3226971230,1727,539efd50-8c2a-11eb-97f4-000c294e8db9,,C:\ForensicAnalysis\Kape_Output\tsv
85030,8,True,16129,2,.\$Recycle.Bin\S-1-5-21-2213123778-2569645789-4120232176-1000,$RMOQ87V.xls:Zone.Identifier,.Identifier,26,1,,False,False,True,False,
False,False,Archive,DosWindows,2021-03-19 10:19:02.5814838,,2021-03-19 10:19:04.6872490,,2021-03-23 23:08:59.6422856,2021-03-23 23:07:55.5032231,2021-03-
19 10:19:02.5814838,,1174991112,3226971230,1727,539efd50-8c2a-11eb-97f4-000c294e8db9,, "[ZoneTransfer]
```

Figura 3. Archivos .xls

Los ficheros eliminados identificados mediante análisis del \$MFT y los borradores del cliente de correo son:

Fichero	Tipo	Fecha de borrado
CLIENTES DEL BANCO.xls	Datos financieros	2021-03-23 23:08:59
Plan_de_cuentas.xls	Datos financieros	2021-03-23 23:08:59
RC.F.07 Actualización de Correos.xls	Datos financieros	2021-03-23 23:08:59
HasMyFiles.exe	Herramienta forense	2021-03-23 ~22:55

Tabla 1. Ficheros Eliminados

Los archivos CLIENTES DEL BANCO.xls y Plan_de_cuentas.xls fueron eliminados a través de la papelera de reciclaje, dejando rastro en el \$MFT con fecha 2021-03-23 a las 23:08:59.

El archivo RC.F.07 Actualización de Correos.xls fue eliminado mediante SDelete64 sin dejar rastro en el \$MFT, siendo su existencia confirmada únicamente a través de los borradores del cliente de correo Thunderbird.

Como dato adicional, el análisis del keylogger/key.exe confirma la ejecución manual de comandos desde CMD entre las 12:06 y 12:24 del mismo día, evidenciando un intento deliberado de destruir pruebas.

Punto 3

Elabora un informe forense completo. Este informe debe seguir la estructura que hemos visto en el temario, incluyendo los hallazgos, las conclusiones y las recomendaciones.

Informe Forense Digital

Caso Murciélago

Análisis de Exfiltración de Datos

Campo	Detalle
Analista	Darwin Marcani Rojas
Fecha de análisis	01/05/2026
Referencia del caso	Caso Murciélago — Exfiltración de Datos
Destinatario	D. Jesús Damián Angosto Iglesias
Versión del informe	1.0
Estado	Final

1. Control de Versiones

Versión	Fecha	Autor	Descripción
1.0	01/05/2026	Darwin Marcani Rojas	Versión inicial del informe forense

2. Resumen Ejecutivo

En el marco de la investigación forense denominada "Caso Murciélago", se ha llevado a cabo un análisis exhaustivo de las evidencias digitales proporcionadas: un volcado de memoria RAM (ram.raw) y una imagen de disco (IE11-Win7-VMWare-disk1.vmdk), correspondientes al equipo del empleado del departamento financiero sospechoso de exfiltración de datos.

El análisis confirma que el usuario IEUser llevó a cabo una exfiltración deliberada de documentos financieros confidenciales de la compañía, enviándolos a un competidor externo a través del cliente de correo electrónico Thunderbird. Los documentos exfiltrados incluyen datos de clientes bancarios y planes de cuentas de la empresa.

Adicionalmente, el sospechoso instaló y ejecutó un keylogger (key.exe) para registrar su propia actividad, utilizó herramientas de borrado seguro (SDelete64) para eliminar las evidencias, y contó con la colaboración de al menos un cómplice externo (insider2@fineloans.org).

La contraseña del usuario ha sido recuperada satisfactoriamente, permitiendo el acceso completo al sistema para un análisis más exhaustivo en caso de ser necesario.

3. Línea de Tiempo

Fecha/Hora	Evento	Fuente
2021-03-19 03:21:23	Redacción del primer correo con adjuntos confidenciales dirigido a comunicacion@fakecompany.com	Thunderbird Drafts
2021-03-19 03:27:13	Segundo intento de envío del correo con los mismos adjuntos	Thunderbird Drafts
2021-03-19 05:36:34	Comunicación con cómplice insider2@fineloans.org — instrucciones en Base64	Thunderbird Drafts
2021-03-23 17:15:02	Arranque del sistema Windows 7	Volatility - windows.info
2021-03-23 17:28:39	Ejecución de HashMyFiles.exe	Prefetch - \$MFT
2021-03-23 17:49:22	Apertura de Microsoft Edge	Volatility - pstree
2021-03-23 17:50:33	Cierre de Microsoft Edge (71 segundos de uso)	Volatility - pstree
2021-03-23 19:08:10	Ejecución de key.exe (keylogger) desde el escritorio	Volatility - pstree / Prefetch
2021-03-23 19:22:55	Apertura manual del CMD por el usuario	Volatility - pstree
2021-03-23 19:24:25	Ejecución de MagnetRamCapture.exe — volcado de RAM	Volatility - pstree
2021-03-23 19:24:35	Captura completa de la memoria RAM	Volatility - windows.info
2021-03-23 22:55:23	Ejecución de SDelete64 (1ª vez) — borrado seguro de ficheros	Prefetch - SDELETE64.EXE
2021-03-23 23:07:55	Acceso al archivo CLIENTES DEL BANCO.xls	\$MFT
2021-03-23 23:08:31	Acceso al archivo Plan_de_cuentas.xls	\$MFT
2021-03-23 23:08:59	Eliminación de CLIENTES DEL BANCO.xls y Plan_de_cuentas.xls	\$MFT / \$Recycle.Bin
2021-03-20 09:13:44	Conexión USB Kingston DT 2.0 (S/N: 1C1B...)	RegRipper usbstor
2021-03-22 08:31:46	Conexión USB Kingston DT 2.0 (S/N: 1C6F...)	RegRipper usbstor
2021-03-22 08:33:19	Conexión USB Kingston DT 3.0 (S/N: 6C62...)	RegRipper usbstor
2021-03-23 17:48:26	Conexión USB Kingston DT 3.0 (S/N: E0D5...)	RegRipper usbstor

4. MITRE ATT&CK TTPs

Táctica	Técnica	ID	Descripción
Collection	Data from Local System	T1005	Acceso y recopilación de documentos financieros confidenciales (.xls)
Exfiltration	Exfiltration Over Web Service	T1567	Exfiltración mediante cliente de correo Thunderbird a competidor externo
Defense Evasion	Indicator Removal - File Deletion	T1070.004	Uso de SDelete64 para eliminación permanente de ficheros sin dejar rastro
Collection	Input Capture - Keylogging	T1056.001	Instalación y ejecución de keylogger (key.exe) en el sistema
Persistence	Valid Accounts	T1078	Uso de credenciales legítimas del usuario IEUser
Command and Control	Remote Access Software	T1219	SSH instalado y activo en el equipo (puerto 22)
Discovery	System Information Discovery	T1082	Uso de herramientas de reconocimiento del sistema (ipconfig, net users)
Exfiltration	Exfiltration to Cloud Storage	T1567.002	Exfiltration to Cloud Storage (Google Drive)
Resource Development	Acquire Infrastructure - Web Services	T1583.006	Acquire Infrastructure (FakeMail para comunicación anónima)

5. Descripción del Incidente

La investigación se inició tras la detección de una grave crisis de filtración de datos económicos en la compañía. El CEO reportó la sospecha de que información confidencial había sido exfiltrada a un competidor desde un equipo interno del departamento financiero.

El equipo analizado corresponde al ordenador personal del empleado identificado como la última persona con acceso a los documentos financieros en cuestión. El sistema operativo del equipo es Windows 7 SP1 de 64 bits, con el usuario principal IEUser.

5.1 Alcance de la investigación

El análisis forense tuvo como objetivo responder a las siguientes preguntas clave planteadas por el docente:

- **ACCESO A ARCHIVOS:** ¿Se accedió a los documentos confidenciales, y en qué fecha y hora?
- **EXFILTRACIÓN Y EVIDENCIA DE ATAQUE:** ¿Existen indicios de herramientas o técnicas (TTPs) utilizadas para la exfiltración de datos?
- **DISPOSITIVOS EXTERNOS:** ¿Se conectó algún dispositivo de almacenamiento USB al equipo?
- **CONEXIONES A LA NUBE:** ¿Hubo intentos de conexión a servicios de almacenamiento en la nube o correos web externos?

6. Dispositivos Proporcionados

Las evidencias fueron proporcionadas directamente por el docente a través del directorio de recursos de la tarea. No fue necesaria la adquisición in situ. Las evidencias recibidas son las siguientes:

Evidencia	Tipo	Tamaño	Hash SHA256
ram.raw	Volcado de memoria RAM	~5 GB	a0ad93b20cd9294f9d49947e87675c12159e3d96ae0d3c5a547f232630b0b240
IE11-Win7-VMWare-disk1.vmdk	Imagen de disco VMware	~20 GB	60919a3adc8450fa7e720ee68f6815d2179673c21c1844f198d7e45b38497068

7. Trabajos Realizados

7.1 Verificación de Integridad

Antes de iniciar el análisis se procedió a verificar la integridad de ambas evidencias mediante el cálculo de sus hashes SHA256 utilizando la herramienta CertUtil de Windows:

- certutil -hashfile ram.raw SHA256
- certutil -hashfile IE11-Win7-VMWare-disk1.vmdk SHA256

7.2 Análisis de Memoria RAM — Volatility 3

7.2.1 Identificación del sistema

Se ejecutó el plugin windows.info para identificar el sistema operativo y obtener información del volcado de memoria:

Parámetro	Valor
Sistema Operativo	Windows 7 SP1 (NTBuildLab: 7601.24384)
Arquitectura	64 bits (x64)
Fecha del volcado	2021-03-23 19:24:35 UTC
Procesadores	1

7.2.2 Hallazgo 1 — Contraseña del usuario

Mediante el plugin windows.hashdump se extrajeron los hashes de contraseñas de todos los usuarios del sistema:

Usuario	RID	Hash NT	Contraseña
Administrator	500	fc525c9683e8fe067095ba2ddc971889	Passw0rd!
Guest	501	31d6cfe0d16ae931b73c59d7e0c089c0	(vacía)
IEUser	1000	fc525c9683e8fe067095ba2ddc971889	Passw0rd!
sshd	1001	31d6cfe0d16ae931b73c59d7e0c089c0	(vacía)
sshd_server	1002	8d0a16cfc061c3359db455d00ec27035	No crackeada
testuser	1003	259745cb123a52aa2e693aaacca2db52	No crackeada

El hash NT del usuario IEUser (fc525c9683e8fe067095ba2ddc971889) fue crackeado mediante el servicio online CrackStation, obteniendo la contraseña en texto claro: Passw0rd!

Se destaca que Administrator e IEUser comparten el mismo hash NT, lo que implica que ambas cuentas tienen la misma contraseña. Esto constituye una mala práctica de seguridad grave.

7.2.3 Hallazgo 2 — Procesos sospechosos

El análisis del árbol de procesos mediante windows.pstree reveló los siguientes procesos de interés:

PID	Proceso	Ruta	Hora inicio	Observación
1600	cmd.exe	C:\Windows\System32\cmd.exe	19:22:55	Abierto manualmente por el usuario
3856	key.exe	C:\Users\IEUser\Desktop\key.exe	19:08:10	Ejecutable desconocido — KEYLOGGER
2324	MagnetRam Capture.exe	C:\Users\IEUser\Desktop\	19:24:25	Herramienta de volcado de RAM
1832	hMailServer.exe	C:\Program Files (x86)\hMailServer\	17:15:45	Servidor de correo instalado
948	sshd.exe	C:\Program Files\OpenSSH\	17:15:47	SSH activo — acceso remoto
1816	msedge.exe	Microsoft Edge	17:49:22	Abierto solo 71 segundos

7.2.4 Hallazgo 3 — Conexiones de red

El análisis de conexiones de red mediante windows.netscan reveló los siguientes hallazgos relevantes:

IP / Puerto	Proceso	Estado	Observación
200.228.36.6	Desconocido	CLOSED	IP externa en Brasil — Claro/Embratel (AS4230)
Puerto 25 (SMTP)	hMailServer.exe	LISTENING	Envío de correos activo
Puerto 110 (POP3)	hMailServer.exe	LISTENING	Recepción de correos
Puerto 143 (IMAP)	hMailServer.exe	LISTENING	Recepción de correos
Puerto 22 (SSH)	sshd.exe	LISTENING	Acceso remoto activo

7.3 Análisis de Imagen de Disco

7.3.1 Montaje de la evidencia

La imagen de disco fue montada en modo solo lectura mediante OSFMount, asignándosele la letra de unidad D:. Este proceso garantiza que la evidencia no fue modificada durante el análisis.

7.3.2 Extracción de artefactos — KAPE

Se utilizó KAPE para la extracción automatizada de artefactos forenses del disco montado, incluyendo: Prefetch, Registro de Windows, EventLogs, Papelera de Reciclaje y sistema de archivos (\$MFT).

7.3.3 Hallazgo 4 — Análisis del escritorio del usuario

El análisis del escritorio del usuario IEUser reveló los siguientes archivos de interés:

Archivo	Tamaño	Fecha	Descripción
key.exe	6.432.221 bytes	19/03/2021 14:00	Keylogger — registra todas las pulsaciones de teclado
pass.txt	136 bytes	19/03/2021 14:19	Nota del docente indicando uso de Volatility
leeme.txt.bak	113 bytes	19/03/2021 12:30	Mensaje cifrado con César — pista de investigación
EULAaccepted.dat	60 bytes	23/03/2021 21:24	Confirma aceptación del EULA de SDelete64
log\log.log	7.728 bytes	23/03/2021 21:24	Log del keylogger con actividad del usuario

7.3.4 Hallazgo 5 — Keylogger (key.exe)

El archivo key.exe es un keylogger desarrollado en Python (empaquetado con PyInstaller) que registró toda la actividad de teclado del usuario. El análisis del archivo log.log generado por este keylogger reveló información crítica:

- Email del competidor: comunicacion@fakecompany.com
- Email del cómplice: insider2@fineloans.org
- Instrucciones de exfiltración codificadas en Base64
- Confirmación de la tarea completada: "Enviar datos empresa - Done"
- Comandos del CMD ejecutados manualmente (del, cd, net users, ipconfig)
- Los archivos exfiltrados eran de tipo .xls (Excel)

7.3.5 Hallazgo 6 — Ejecución de comandos y borrado

Durante el análisis del sistema se identificó el uso de SDelete64, herramienta de Microsoft Sysinternals diseñada para la eliminación permanente de archivos, eludiendo la papelera de reciclaje y sobrescribiendo el espacio en disco para dificultar su recuperación.

El análisis del archivo Prefetch SDELETE64.EXE-1BCED5FB.pf confirma que dicha herramienta fue ejecutada en 2 ocasiones desde el escritorio del usuario IEUser, registrándose la última ejecución el 2021-03-23 a las 22:55:23 UTC.

Fichero eliminado	Tipo	Método de borrado	Fecha	Fuente confirmación
CLIENTES DEL BANCO.xls	Datos financieros	Papelera + vaciado	23/03/2021 23:08:59	\$MFT / \$Recycle.Bin
Plan_de_cuentas.xls	Datos financieros	Papelera + vaciado	23/03/2021 23:08:59	\$MFT / \$Recycle.Bin
RC.F.07 Actualizacion de Correos.xls	Datos financieros	SDelete64 (sin rastro MFT)	~23/03/2021 22:55	Thunderbird Drafts
HasMyFiles.exe	Herramienta forense	SDelete64 (sin rastro MFT)	~23/03/2021 22:55	Prefetch

7.3.6 Hallazgo 7 — Análisis de correo electrónico (Thunderbird)

El análisis del perfil de Thunderbird del usuario IEUser reveló 3 borradores de correo electrónico con información crítica sobre la exfiltración:

Correo	Fecha	De	Para	Adjuntos
1	19/03/2021 03:21	insider@pruebas.local	comunicacion@fakecompany.com	CLIENTES DEL BANCO.xls, Plan_de_cuentas.xls, RC.F.07 Actualizacion de Correos.xls
2	19/03/2021 03:27	insider@pruebas.local	comunicacion@fakecompany.com	CLIENTES DEL BANCO.xls, Plan_de_cuentas.xls, RC.F.07 Actualizacion de Correos.xls
3	19/03/2021 05:36	insider@pruebas.local	insider2@fineloans.org	Sin adjuntos — "Las instrucciones están en B64"

El cuerpo del primer correo indica: "Ya tengo los documentos solicitados para que podáis hacer la contraoferta. Te los remito adjuntos a este mensaje.", lo que confirma la coordinación previa entre el sospechoso y el competidor.

7.3.7 Hallazgo 8 — Dispositivos USB conectados

Durante el análisis del registro de Windows mediante RegRipper (plugin usbstor) se identificaron 4 dispositivos USB Kingston DataTraveler conectados al equipo en el período de investigación:

Dispositivo	Número de Serie	Fecha de conexión
Kingston DataTraveler 2.0	1C1B0D0194C9B361D9569B82	2021-03-20 09:13:44 U
Kingston DataTraveler 2.0	1C6F654FF40FBDB07911153E	2021-03-22 08:31:46 U
Kingston DataTraveler 3.0	6C626D7C2772F1A0B9580507	2021-03-22 08:33:19 U
Kingston DataTraveler 3.0	E0D55E6C382BF42049D34449	2021-03-23 17:48:26 U

El dispositivo más relevante es el último, conectado el 2021-03-23 a las 17:48:26 UTC, exactamente un minuto antes de la apertura de Microsoft Edge (17:49:22 UTC). Esta proximidad temporal sugiere una posible relación entre ambos eventos.

8. IOCs — Indicadores de Compromiso

Tipo	Valor	Descripción
Email	comunicacion@fakecompany.com	Destinatario de los documentos exfiltrados (competidor)
Email	insider@pruebas.local	Cuenta de correo del sospechoso en el servidor local
Email	insider2@fineloans.org	Email del cómplice externo
IP	200.228.36.6	IP externa contactada — Claro/Embratel, Brasil (AS4230)
Hash NT (NTLM)	fc525c9683e8fe067095ba2ddc971889	Hash NT de la contraseña Passw0rd! (IEUser / Administrator)
Archivo	key.exe	Keylogger ejecutado desde el escritorio del usuario

Archivo	SDELETE64.EXE	Herramienta de borrado seguro utilizada para destruir evidencias
Archivo	CLIENTES DEL BANCO.xls	Documento financiero confidencial exfiltrado
Archivo	Plan_de_cuentas.xls	Documento financiero confidencial exfiltrado
Archivo	RC.F.07 Actualizacion de Correos.xls	Documento financiero confidencial exfiltrado
Puerto	22 (SSH)	Servicio SSH activo — posible vector de acceso remoto
Puerto	25 / 110 / 143 / 587	Puertos de correo de hMailServer activos
Software	hMailServer	Servidor de correo instalado en equipo de usuario estándar
Usb	Kingston DataTraveler 2.0 — S/N: 1C1B0D0194C9B361D9569B82	Conectado 20/03/2021
Usb	Kingston DataTraveler 2.0 — S/N: 1C6F654FF40FBDB07911153E	Conectado 22/03/2021
Usb	Kingston DataTraveler 3.0 — S/N: 6C626D7C2772F1A0B9580507	Conectado 22/03/2021
Usb	Kingston DataTraveler 3.0 — S/N: E0D55E6C382BF42049D34449	conectado 23/03/2021 — sospechoso

9. Conclusiones

9.1 ¿Se accedió a los documentos confidenciales?

SÍ. El análisis del \$MFT confirma el acceso a los documentos CLIENTES DEL BANCO.xls el 2021-03-23 a las 23:07:55 UTC y Plan_de_cuentas.xls a las 23:08:31 UTC. Adicionalmente, los borradores de Thunderbird confirman el acceso y envío del archivo RC.F.07 Actualización de Correos.xls desde el 19/03/2021.

9.2 ¿Existen indicios de exfiltración y TTPs?

SÍ. Se han identificado múltiples TTPs del framework MITRE ATT&CK:

- Instalación de keylogger (key.exe) para monitorización de la actividad
- Uso de cliente de correo Thunderbird con servidor hMailServer para exfiltrar documentos
- Coordinación con cómplice externo mediante correo cifrado en Base64
- Uso de SDelete64 para destruir evidencias de forma permanente
- Conexión a IP externa en Brasil (200.228.36.6)

9.3 ¿Se conectó algún dispositivo USB?

SÍ. El análisis del registro de Windows mediante el plugin usbstor de RegRipper confirmó la conexión de 4 dispositivos USB Kingston DataTraveler entre el 20/03/2021 y el 23/03/2021. El dispositivo más relevante (Kingston DataTraveler 3.0, S/N: E0D55E6C382BF42049D34449) fue conectado el 2021-03-23 a las 17:48:26, un minuto antes de que el usuario abriera Microsoft Edge, lo que sugiere una posible relación entre ambos eventos. No fue posible determinar con certeza el contenido transferido sin un análisis adicional de los dispositivos físicos.

9.4 ¿Hubo conexiones a la nube o correos web?

Se detectó el uso de Microsoft Edge durante un período de 71 segundos (17:49:22 - 17:50:33 UTC del 23/03/2021). Adicionalmente, se detectó una conexión a la IP externa 200.228.36.6 (Claro/Embratel, Brasil) con estado CLOSED.

El análisis del historial de Microsoft Edge reveló múltiples conexiones a servicios externos de alto interés forense:

URL / Servicio	Descripción
drive.google.com	Subida de Plan_de_cuentas.xls y CLIENTES DEL BANCO.xls
fakemail.net	Correo temporal anónimo — visitado 3 veces
accounts.google.com/signin → Gmail	Intento de acceso a Gmail
bing.com → "monedero bitcoin anónimo"	Búsqueda de cobro anónimo
etoro.com	Plataforma de criptomonedas
bing.com → "configurar ssh windows"	Instalación deliberada de SSH

El historial de Edge confirma además la subida de documentos confidenciales a Google Drive, el uso de FakeMail como correo anónimo y búsquedas relacionadas con cobro en Bitcoin, lo que sugiere motivación económica detrás de la exfiltración.

9.5 Conclusión general

La evidencia recopilada demuestra de forma concluyente que el usuario IEUser llevó a cabo una exfiltración premeditada y coordinada de documentos financieros confidenciales de la compañía. La naturaleza deliberada de las acciones queda evidenciada por la instalación de herramientas específicas (keylogger, servidor de correo), la coordinación con un cómplice externo y los intentos sistemáticos de destruir las evidencias mediante SDelete64.

10. Recomendaciones y Plan de Acción

Prioridad Alta — Acción inmediata

- Preservar el equipo analizado como evidencia para posibles acciones legales y no encenderlo ni modificarlo.
- Revocar inmediatamente las credenciales del usuario IEUser y bloquear su acceso a todos los sistemas de la compañía.
- Notificar a las autoridades competentes dado que existe evidencia de exfiltración de datos confidenciales.
- Identificar y contactar a los destinatarios de los correos (comunicacion@fakecompany.com) para evaluar el alcance del daño.

Prioridad Media — Corto plazo

- Implementar una solución DLP (Data Loss Prevention) para prevenir la exfiltración de datos a través de correo electrónico y otros canales.
- Auditar todos los accesos a documentos financieros confidenciales en el período previo al incidente.
- Eliminar el servidor SSH instalado en el equipo del sospechoso y revisar si existieron conexiones remotas no autorizadas.
- Bloquear la IP 200.228.36.6 en el firewall perimetral y revisar logs de red en busca de otras conexiones sospechosas.
- Revisar todos los equipos del departamento financiero en busca de software similar (keyloggers, servidores de correo no autorizados).
- Bloquear el acceso a servicios de correo temporal (fakemail.net) y revisar las políticas de uso de Google Drive en equipos corporativos.

Prioridad Baja — Largo plazo

- Implementar una política de contraseñas robusta que prohíba contraseñas comunes como Passw0rd! y exija contraseñas únicas por cuenta.
- Establecer una política de uso de dispositivos USB con control mediante soluciones de endpoint security.
- Impartir formación en concienciación de seguridad a todos los empleados, especialmente del departamento financiero.
- Implementar monitorización continua de la red (SIEM) para detectar comportamientos anómalos en tiempo real.
- Revisar y reforzar los controles de acceso a documentos financieros aplicando el principio de mínimo privilegio.